

3.1.3 Practice - Active Reconnaissance vs. Passive Reconnaissance

Question 1

Which three reconnaissance tools or methods are considered active reconnaissance? (Choose three.)

☒ packet crafting

☒ network share enumeration

☐ eavesdropping

☒ host enumeration

☐ domain enumeration

☐ packet inspection

Question 2

Which three reconnaissance tools or methods are considered passive reconnaissance? (Choose three.)

☒ domain enumeration

☐ packet crafting

☒ Recon-ng

☐ service enumeration

☒ open-source intelligence

☐ user enumeration

Skills Check

You are planning to use SpiderFoot to discover details about the Pixel Paradise domain as part of the reconnaissance effort. Which SpiderFoot use case should be used so that Pixel Paradise security staff will be not be aware of your activities?

- All
- Footprint
- Investigate
- ☒ Passive

3.1.6 Practice - DNS Lookups

A user enters the command `dig h4kerone.org mx` on a Linux host. What is the purpose of using this command?

- to send a test email to the h4kerone.org server
- ☒ to obtain the email servers used by h4kerone.org
- to test the connectivity to the h4kerone.org server
- to find the IP address associated with the domain name h4kerone.org

3.1.8 Practice - Identification of Technical and Administrative Contracts

Which command can identify the technical and administrative contacts for the domain `h4cker.org`?

- ping h4cker.org
- ☒ whois h4cker.org
- dig h4cker.org
- nslookup h4cker.org

Skills Check

You need to do a DNS reverse lookup on an IP address that you uncovered during an investigation. Which option will tell dig to return the domain name and record type for the IP address?

AAAA

-ns

-b

 -x

Skills Check

Which Kali SSL reconnaissance tool queries SSL services to determine what cyphers are supported?

ssldump

sslh

 sslscan

sslsplit

3.1.16 Practice - File Metadata

An attacker downloaded the file `ourmission.jpg` from a government office website. The attacker then issued a command `exiftool ourmission.jpg` on the workstation. What is the purpose of this operation?

to encrypt the file for transmission to the dark web

to convert the file from image to PDF format

to embed malicious codes into the file

 to obtain information contained in the metadata of the file

3.1.17 Practice - Web Archiving, Caching, and Public Code Repositories

A cybersecurity professional is helping the XYZ corporation to perform vulnerability assessments of the web services. The professional performed a Google search with the following string:

```
xyz.com intext:JSESSIONID OR intext:PHPSESSID inurl:access.log ext:log
```

Which term describes the part "intext:JSESSIONID OR intext:PHPSESSID inurl:access.log ext:log"?

- Google caching
- Google archiving
- ☒ Google dork
- Google phishing

Skills Check

What types of files will ExifTool read metadata from? (Choose three.)

- ☒ MP3 audio
- ☒ PNG graphics
- ☒ MP4 video
- SQL data tables

Skills Check

Which statements are true regarding this Google dork? (Choose three.)

```
inurl:"/private" intext:"index of /" "win64" -litespeed
```

- It will return all pages that include the term "litespeed" in the page.
- ☒ It will return pages that have the term "private" in the URL.
- ☒ It will return pages that have both "index of /" AND "win64" in the page text.
- It will return links to files that are part of a 64-bit Windows server system
- ☒ It will return pages that have "index of /" OR "win64" in the page text.

Skills Check

Which statement is true regarding a Shodan search on the term "webcam?"

- ☒ It will return all pages that include the term "webcam" in service banners.
- ☐ It will return only webcam server pages.

3.2.3 Practice - Nmap Scan Types

Question 1

A cybersecurity technician is using the Nmap tool to perform a port scan using the command:

```
nmap -sn 172.16.50.0/24
```

Which type of port scan is being used by the technician?

- ☒ host discovery scan
- ☐ TCP FIN scan
- ☐ TCP connect scan
- ☐ UDP scan

Question 2

An attacker is using the Nmap tool to perform a port scan with the command:

```
nmap -sn -T0 172.18.12.0/24
```

What is the purpose of using option -T0?

- ☒ to avoid being detected by IDS or IPS
- ☐ to perform the scan aggressively
- ☐ to stop the scan after a time period specified by T0
- ☐ to run the scan about 10 times slower than the default

3.2.5 Practice - Exploring Enumeration via Packet Crafting with Scapy

Which tool can be used by an attacker to generate modified packets?

- Nmap
- Scapy
- ExifTool
- Recon-ng

3.2.8 Practice - Packet Inspection and Eavesdropping

Which tools can be used to perform passive reconnaissance? (Choose three.)

- Nikto
- Nmap
- tshark
- tcpdump
- Wireshark
- enum4linux

Skills Check

You want to send a packet to the well-known HTTP port on host 192.168.99.17 with the TCP SYN flag set. What options will you use with the Scapy `send()` function to craft this packet? (Choose three.)

IP(dst="192.168.99.17")

TCP(flags="SN")

TCP(dport=80)

TCP(dport=8080)

TCP(flags="S")

3.3.3 Practice - How a Typical Automated Vulnerability Scanner Works

Match the steps in a typical vulnerability scan to the description.

Categories:

Step 1

Step 2

Step 3

Step 4

Options:

A

B

C

D

D

A

B

C

The scanner produces a report on what it suspects could be vulnerable.

In the discovery phase, the scanner uses a tool such as Nmap to perform host and port enumeration.

The scanner records what software and version are running on an open port into a database for further analysis.

The scanner tries to determine if the software that is listening on the target system is susceptible to any known vulnerabilities.

Submit

Show feedback

3.3.5 Practice - Types of Vulnerability Scans

In your role as a pentester at Protego, you will conduct a variety of vulnerability scans. It is important that you know the types of scans available and what each can do for you. Match each type of vulnerability scan its description.

Categories:

unauthenticated scan

authenticated scan

discovery scan

stealth scan

compliance scan

full scan

Options:

A

A

✓

The scan shows only the network services that are exposed to the network. The scanner attempts to enumerate the ports open on the target host.

B

E

✓

The scan typically tests networks and applications driven by requirements from the market, governance, or regulations that serve the environment.

C

C

✓

The scan is primarily meant to identify the attack surface of a target. Performing a port scan is a major part of this type of scan.

D

B

✓

The scan requires that a set of credentials that have root-level access to the system be provided to the scanner.

E

D

✓

The scan requires running scanning processes without alerting the defensive position of the environment.

F

F

✓

The scan typically involves enabling every scanning option in the scan policy.

Skills Check

Which statements describe the output from the command shown? (Choose three.)

Note: Line numbers in bracket [] were added for the purposes of the question.

```
└─(kali@Kali)-[~]

└─$ nmap -sV --script vulners --script-args mincvss=4 203.0.113.132
PORT      STATE SERVICE      VERSION
[output omitted]
22/tcp    open  ssh          OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
vulners:
| CVE-2016-7407 10.0 https://vulners.com/cve/CVE-2016-7407 [1]
| CVE-2021-41617 4.4 https://vulners.com/cve/CVE-2021-41617 [2]
| CVE-2019-16905 4.4 https://vulners.com/cve/CVE-2019-16905 [3]
| CVE-2019-6110 4.0 https://vulners.com/cve/CVE-2019-6110 [4]
| CVE-2016-10011 2.1 https://vulners.com/cve/CVE-2016-10011 [5]
[output omitted]
```

✓

All of the discovered vulnerabilities concern features of OpenSSH 2.0.

✓

Line [1] This vulnerability should be mitigated before the others.

Line [2] This vulnerability was discovered in 2020.

Line [3] This was discovered earlier in the year than Line [4].

✓

Line [5] This would not appear in the output of the command shown.

Skills Check

What is a summary of vulnerability CVE-2019-6111?

☒

man-in-the-middle (MITM) vulnerability

☐

OpenSSH access restrictions bypass

☐

weak SSL encryption

☐

path traversal

Submit

☒ Show feedback

Question 1

Which two tools could be used to gather DNS information passively? (Choose two.)

☒

Recon-ng

☒

Dig

☐

Wireshark

☐

Nmap

☐

ExifTool

Question 2

When performing passive reconnaissance, which Linux command can be used to identify the technical and administrative contacts of a given domain?

☐

netstat

☐

dig

☒

whois

☐

nmap

Question 3

Which specification defines the format used by image and sound files to capture metadata?

- ☒ Exchangeable Image File Format (Exif)
- ☐ Extensible Image File Format (Exif)
- ☐ Exchangeable File Format (EFF)
- ☐ Interchangeable File Format (IFF)

Question 4

Why would a penetration tester perform a passive reconnaissance scan instead of an active one?

- ☒ to collect information about a network without being detected
- ☐ because the time to perform the scan is limited
- ☐ because the root-level SSH credentials to a target have been compromised
- ☐ to test whether specific services or protocols are available on the network

Question 5

What type of server is a penetration tester enumerating when they enter the `nmap -sU` command?

- ☒ DNS, SNMP, or DHCP server
- ☐ HTTP or HTTPS server
- ☐ POP3, IMAP, or SMTP server
- ☐ FTP server

Question 6

What is the disadvantage of conducting an unauthenticated scan of a target when performing a penetration test?



Vulnerability of services running inside the target may not be detected.

The scanner will report the port as open whether or not the service on that network segment is listening or not.

Unauthenticated scans are more likely to provide a lower rate of false positives than authenticated scans.

Unauthenticated scans are a form of passive reconnaissance that return little useful information.

Question 7

What is required for a penetration tester to conduct a comprehensive authenticated scan against a Linux host?



user credentials with root-level access to the target system

system user credentials

physical on-premises access to the target system

unauthenticated scans are a form of passive reconnaissance that return little useful information.

backdoor access to the target system

Question 8

In which circumstance would a penetration tester perform an unauthenticated scan of a target?



when user credentials were not provided

when the number of false positive vulnerability reports is not required

when time is limited and faster scans are required

when only targets with UDP services are to be scanned

Question 9

Why would a penetration tester use the **nmap -sF** command?



when a TCP SYN scan is detected by a network filter or firewall

when the tester wants to conclude the scan

when a TCP SYN scan reports more than one open port

when the tester needs to time stamp the scan

Question 10

What is the purpose of host enumeration when beginning a penetration test?



to identify all active IP addresses within the scope of the test

to count the total number of IP addresses within the scope of the test

to identify all vulnerable hosts within the scope of the test

to count the total number of vulnerable hosts within the scope of the test

Question 11

What can be deduced when a tester enters the **nmap -sF** command to perform a TCP FIN scan and the target host port does not respond?



that the port is open

that the port is not responding to TCP traffic

that the port is listening for UDP traffic

that the port is not ready to close the TCP connection

Question 12

What is the disadvantage of running a TCP Connect scan compared to running a TCP SYN scan during a penetration test?

- ☒ The extra packets required may trigger an IDS alarm.
- ☐ Both open and closed ports are detected.
- ☐ Indeterminate ICMP messages are generated.
- ☐ Hosts and addresses outside the scope of the test may be scanned.

Question 13

When a penetration test identifies a vulnerability, how should the vulnerability be further verified?

- ☒ determine if the vulnerability is exploitable
- ☐ prioritize the vulnerability severity
- ☐ assess the business risk associated with the vulnerability
- ☐ mitigate the vulnerability

Question 14

Why is the Common Vulnerabilities and Exposures (CVE) resource useful when investigating vulnerabilities detected by a penetration test?

- ☒ It is an international consolidation of cybersecurity tools and databases.
- ☐ It is a high level list of software weaknesses.
- ☐ It has three vulnerability score components.
- ☐ It is a dictionary of known attacks.

Question 15

What is the purpose of applying the Common Vulnerability Scoring System (CVSS) to a vulnerability detected by a penetration test?

- ☒ to calculate the severity of the vulnerability
- ☐ to determine the priority of the vulnerability
- ☐ to determine the attack vector that applies to the vulnerability
- ☐ to accurately record how the vulnerability was detected

Question 16

A threat actor is looking at the IT and technical job postings of a target organization. What would be the most beneficial information to capture from these postings?

- ☒ the type of hardware and software used
- ☐ the salaries of the positions listed
- ☐ the hours of work required by the roles listed
- ☐ the employment benefits offered by the company

Question 17

How is open-source intelligence (OSINT) gathering typically implemented during a penetration test?

- ☒ by using public internet searches
- ☐ by installing and running the OSINT API
- ☐ by sending phishing emails
- ☐ by using nmap for web page and web application enumerations

Question 18

What initial information can be obtained when performing user enumeration in a penetration test?

- ☒ a valid list of users
- ☐ the IP addresses of the target hosts
- ☐ the credentials of a specified user
- ☐ access to the target internal network

Question 19

What useful information can be obtained by running a network share enumeration scan during a penetration test?

- ☒ systems on a network that are sharing files, folders, and printers
- ☐ the usernames and password credentials of users on the network
- ☐ all vulnerable hosts on the network
- ☐ lists of the attack vectors that can exploit the network

Question 20

A penetration tester must run a vulnerability scan against a target. What is the benefit of running an authenticated scan instead of an unauthenticated scan?

- ☒ Authenticated scans can provide a more detailed picture of the target attack surface.
- ☐ Authenticated scans are a form of passive reconnaissance that does not trigger target security alarms.
- ☐ Authenticated scans are performed without user credentials.
- ☐ Authenticated scans are less complex and are quicker than unauthenticated scans.

Question 21

What are three considerations when planning a vulnerability scan on a target production network during a penetration test? (Choose three.)

- ☒ the timing of the scan
- ☒ the available network bandwidth
- ☒ the network topology
- ☐ authenticated scans are less complex and are quicker than unauthenticated scans
- ☐ the available scanning tools
- ☐ the trained personnel available to analyze the scan results
- ☐ the scan reporting requirement

Question 22

When performing a vulnerability scan of a target, how can adverse impacts on traversed devices be minimized?

- ☒ The scan should be performed as close to the target as possible.
- ☐ Unauthenticated vulnerability scans should be performed.
- ☐ Only passive reconnaissance scans should be performed.
- ☐ Scanning policy options should include query throttling.

Question 23

A company hires a cybersecurity consultant to conduct a penetration test to assess vulnerabilities in network systems. The consultant is preparing the final report to send to the company. What is an important feature of a final penetration test report?

- ☒ It gives an accurate presentation of vulnerabilities.
- ☐ It follows expected report presentation standards and style.
- ☐ It is a summary of general information so non-technical managers can understand it.
- ☐ It is made publicly available to all interested parties.

Question 24

What is the advantage of using the target Wi-Fi network for reconnaissance packet inspection?

- ☒ Physical access to the building may not be required.
- ☐ The packet scan takes less time wirelessly compared to using the target wired network.
- ☐ More information can be captured wirelessly compared to using the target wired network.
- ☐ Fewer false positive vulnerabilities are detected.

Question 25

What guidance does the NIST Cybersecurity Framework provide to help improve an organization's cybersecurity posture?

- ☒ The framework outlines standards and industry best practices.
- ☐ The framework provides a global consolidation of cybersecurity tools and databases.
- ☐ The framework lists cyber attacks that have been seen in the real world.
- ☐ The framework provides a vulnerability scoring system.